

ATT&CK Based Practice Guide Evaluation

Midterm Report

November 1, 2019

Institution: The University of Texas at Dallas - Team Lost Girls

Team Members:

Anmol Agarwal	Anmol.Agarwal@utdallas.edu
Rhiannon Jones	Rhiannon.Jones@utdallas.edu
Evelyn Wong	Evelyn.Wong@utdallas.edu

Table of Contents

Table of Contents	2
Project Summary	3
Description	3
Team Responsibilities	3
Total Budget	3
Motivation	3
Literature Review	3
1 MITRE ATT&CK™: Design and Philosophy	3
2 Finding Cyber Threats with ATT&CK™: Based Analytics	4
3 Towards a definition of cyberspace tactics, techniques and procedures	4
4 Caldera	5
Progress	5
Overview	5
Detailed Plan	6
Challenges	6
Organization	6
Plans	6
Deliverables	6
Tentative Schedule	6
Budget	7
Broader Impact	7
Biographical Sketches of Investigators	7
Anmol Agarwal	7
Rhiannon Jones	7
Evelyn Wong	8
References	8

Project Summary

Description

NCCoE Practice Guides target cybersecurity challenges. These guides are helpful and provide easy ways to adopt standards-based approaches to cybersecurity. The goal of this project is to identify any security gaps in the Access Rights Management Practice Guide's architecture by analyzing the test cases in the NCCoE Practice Guide. Specifically, this project aims to find the techniques and tactics the Practice Guide protects against by evaluating the scenarios in the guide against the attacks in the MITRE ATT&CK Enterprise Matrix. The team will document their findings while analyzing the different techniques.

Team Responsibilities

- Review the architecture in Volume B, Access Rights Management for the Financial Services Sector [4]
- Specify appropriate techniques and tactics that is applicable to attack the framework.
- Perform a Tabletop exercise to attack the framework described in Volume B and document results
 - Attacks will change directories and account attributes
- Review Tabletop exercise results

Total Budget

The team will spend ten hours per week on the project.

Motivation

The architectures described in the NCCoE Practice Guides are theoretical and have never been evaluated or tested. By performing tabletop exercises to attempt to attack the framework described in Volume B of the Access Rights Management Practice Guide [4], this project will help evaluate the architecture for the first time and help to improve the architecture by exposing any flaws in its design.

Literature Review

1 MITRE ATT&CK™: Design and Philosophy

This paper describes the MITRE ATT&CK framework. ATT&CK is a knowledge base for the behavior of malicious cybersecurity actors. It has tactics and techniques that the adversaries use

to exploit certain software. Tactics are the short term goals that the attacker uses and the techniques are the actions the malicious user does in an attempt to exploit the software. ATT&CK can be visualized in a matrix with tactics representing the columns of the matrix and the techniques representing the rows of the matrix.

ATT&CK covers the following technological domains: macOS, Linux, Windows, Android, and iOS. ATT&CK describes cybersecurity exploits by depicting them from the malicious user's point of view, is based on actual examples that occurred, and helps to determine possible defensive strategies from the offensive strategies.

ATT&CK is a useful framework for emulating adversarial behavior and can help blue teams develop defensive strategies by observing the attacker behavior from ATT&CK.

2 Finding Cyber Threats with ATT&CK™: Based Analytics

This paper describes a methodology for using a behavior-based threat model (MITRE ATT&CK) to develop detection capabilities that detect adversaries through the use of adversary emulation. The methodology includes seven steps: Identify Behaviors, Acquire Data, Develop Analytics, Develop an Adversary Emulation Scenario, Emulate Threat, Investigate Attack, and Evaluate Performance.

The focus of the Identify Behaviors step is to identify the adversary behaviors to detect and to prioritize them. The Acquire Data step aims to find what data is necessary to identify the targeted adversary behaviors and create sensors to collect any data that does not have a current collection capability. Develop Analytics creates the analytics used to detect the behaviors identified in the first step. Next is to Develop an Adversary Emulation Scenario which develops a scenario that emulates adversary behavior including the identified behaviors from step one. The Emulate Threat step and Investigate Attack threats are Red Team/Blue Team activities where the Red Team attempts to carry out the objectives defined in the emulation scenario and the Blue Team attempts to detect the Red Team's activities using the analytics developed in the third step. The final step is to Evaluate Performance where the entire engagement is reviewed and the extent to which adversary behaviors were detected with the developed analytics and sensors.

3 Towards a definition of cyberspace tactics, techniques and procedures

This paper define TTPs which stands for Tactics, Techniques and Procedures. It describes an approach to developing models of offensive cyberspace operations (OCO). Developing actionable behavioral models of OCO for an autonomous system allow defensive systems to

detect attacks and predict future actions. The model described discussed how it applies to real-world cyberspace operations examples. Given an attack graph, an attacker emulator could work backwards. Their approach captures optional elements where they're able to show a representation of all known permutations of an attack and still add new variations as they are observed. This approach is compatible with ATT&CK. In 2015, MITRE released its Adversarial Tactics, Techniques (ATT&CK) model, that takes about post-compromise behaviors [2]. In which, ATT&CK describes ten categories of tactics.

The model of Advanced Persistent Threat (APT) 28 technique is used with the approach describes how it can be applied to real-world cyberspace operations. It also explains their approach and how it could be used by Machine Learning (ML) algorithms to detect and represent an ongoing attack. Research this approach on TTPs help provide predictive analytics based on large security datasets.

4 Caldera

Caldera is an automated red team tool. It uses the ATT&CK model to replicate adversary behaviors, thereby enabling automated assessments of a network's security. Caldera uses a decision engine to choose actions in combination with an adversary representation language, the ATT&CK matrix, and an agent to conduct the operation to test a network's defenses. This tool allows for the detection of, and subsequent response to, adversary behavior [5].

Progress

Overview

The overarching goal of this project is to find feasible attacks against the NCCoE's Access Rights Management Practice Guide architecture. To accomplish this, we have studied the architecture proposed in the Practice Guide and researched its components. Specifically, we studied Microsoft Active Directory, RadiantLogic Virtual Directory, and AlertEnterprise Guardian.

After learning more about the architecture and its design, we have also formulated several possible attacks that could be used against the architecture to gain unauthorized access or make unauthorized changes or, in some cases, both.

Detailed Plan

Work completed

The team became familiar with the architecture by reading the Access Rights Management Practice Guide, Volume B as well as parts of Volume C for specific implementation details. We also became familiar with different alerts that were generated in the different layers of the architecture in Volume C.

Work in progress

We, our sponsor, and other MITRE engineers are reviewing the different attacks we brainstormed for feasibility. Once we are able to identify the attacks that could potentially be used against the ARM architecture, we will look into specific implementation details that can be used to carry out the attacks.

Challenges

There was a steep learning curve to learning and understanding the Access Rights Management architecture. We had to understand how every part of the architecture works together and how those parts communicate to create a unified system. To overcome this challenge, our sponsor connected us to another engineer at MITRE, and he was able to explain the tools we are looking at specifically in more detail. He was also able to tell us the alerts the different tools generate and what causes alert generation.

Organization

Plans

The group will meet weekly to ensure progress on the project. The team will use effective time management and communication to ensure that the project continues to progress on schedule.

Deliverables

- Proposal & Literature Review
- Progress Report & Presentation
- Tabletop Exercise Report
- Final Report & Presentation

Tentative Schedule

October 4: Proposal Due

October 11: Read Volume B of the Access Rights Management Practice Guide
October 18: Review ATT&CK Matrix
October 25: Plan Tabletop Exercise
November 1: Midterm Report Due
November 8: Perform Tabletop Exercise
November 15: Finish Tabletop Exercise
November 15: Report Draft of Tabletop Exercise
November 22: Review Final Report
December 6: Final Deliverables Due

Budget

There are no monetary costs associated with this project. The team will meet approximately ten hours/ week and will have weekly status update meetings.

Broader Impact

By analyzing the tactics and techniques that the NCCoE Access Rights Management Practice Guide protects against, the security of the architecture in the Volume B of the Access Rights Management Practice Guide can be improved and strengthened.

Biographical Sketches of Investigators

Anmol Agarwal

Anmol Agarwal is currently pursuing her Bachelor's degree in Software Engineering with a specialization in information assurance and her Master's degree in Computer Science with a specialization in information assurance concurrently. She is also an NSF CyberCorps Scholarship for Service recipient. She has experience in software development, project management, virtual machines, and information security. Anmol has experience with solving CTF (Capture the Flag) challenges, such as challenges in web security and forensics. She has completed coursework in computer networks, digital forensics, information security, artificial intelligence, operating systems, and data and applications security. She is currently taking network security and advanced operating systems. In her free time, Anmol is an active member of Women in CyberSecurity and the Computer Security Group.

Rhiannon Jones

Rhiannon Jones holds a Bachelor's degree in Computer Science and is pursuing a Master's degree in Computer Science with a specialization in information assurance. She has completed an internship with Experian in their Global Security Office, working as a part of the Governance and Controls team. She has experience in virtual machines, vulnerability assessments, software development, and information security. She has related coursework in software engineering, computer networks, information security, operating systems, machine learning, and language-based security. She is currently taking classes in advanced operating systems, machine learning, and network security.

Evelyn Wong

Evelyn Wong is a senior Computer Science major, with a specialization in information assurance. She is currently a fast track student and working on a master's degree in computer science while finishing undergraduate studies. She is also a recipient of the CyberCorps: Scholarship for Service. She has experience practicing and studying attacking techniques and vulnerability in computer and network systems. She has completed related coursework in software engineering, operating systems, computer architecture, computer network security. She is currently taking computer networks, database design, and automata theory.

References

- [1] B. Strom, A. Applebaum, D. Miller, K. Nickels, A. Pennington and C. Thomas. (2018). "MITRE ATT&CK™: Design and Philosophy," [online] McLean, VA: MITRE Corporation.
Available at: <https://www.mitre.org/sites/default/files/publications/pr-18-0944-11-mitre-attack-design-and-philosophy.pdf> [Accessed 27 Sep. 2019].
- [2] B. E. Strom, J. A. Battaglia, M. S. Kemmerer, W. Kupersanin, D. P. Miller, C. Wampler, S. M. Whitley and R. D. Wolf, "Finding Cyber Threats with ATT&CK-Based Analytics," 2017. Available at: <https://www.mitre.org/sites/default/files/publications/16-3713-finding-cyber-threats%20with%20att&ck-based-analytics.pdf> [Accessed 27 Sep. 2019].
- [3] F. Maymí, R. Bixler, R. Jones and S. Lathrop, "Towards a definition of cyberspace tactics, techniques and procedures," 2017 IEEE International Conference on Big Data (Big Data), Boston, MA, 2017, pp. 4674-4679. doi: 10.1109/BigData.2017.8258514. Available at: <https://ieeexplore.ieee.org/abstract/document/8258514> [Accessed 27 Sep. 2019].

2019].

- [4] J. Banoczi, S. Edwards, N. Irrechukwu, J. Klosterman, H. Perper, S. Prince, S. Symington, and D. Wynne, “Access Rights Management for the Financial Services Sector,” National Institute of Standards and Technology Special Publication, Gaithersburg, MD, 2017.
- [5] The MITRE Corporation. (2019). CALDERA. [online] Available at: <https://www.mitre.org/research/technology-transfer/open-source-software/caldera> [Accessed 27 Sep. 2019].